

Analiza și îmbunătățirea sistemului informational

eMag folosind principiile O-ESA

1. Analiza sistemului informațional actual al eMag

Arhitectură și componente:

- 🚦 eMag, fiind cel mai mare retailer online din România, utilizează un sistem informațional complex, interconectat, care susține milioane de tranzacții lunare. Acest sistem este alcătuit din:
 - Portal web (frontend): Accesibil clienților prin browsere web sau aplicații mobile. Include pagini pentru produse, coșul de cumpărături, autentificare, contul clientului, metode de plată și istoricul comenzilor.
 - Servere backend: Intermediază comunicarea dintre interfața utilizatorului și baza de date. Procesează cererile de căutare, înregistrare, plată și actualizare a stocurilor.
 - Bază de date centrală: Conține informații sensibile, precum:
 - Datele personale ale clienților (nume, adresă, email, telefon),
 - Informații despre comenzi și tranzacții,
 - Detalii despre stocuri și produse.
 - Sistem de plăți: eMag lucrează cu parteneri de plăți precum PayU. Suportă carduri bancare, plăți online prin aplicații bancare sau portofele digitale.
 - Sistem de logistică și livrare: Actualizează automat stocurile, trimite comenzi către curieri și gestionează returnuri.
 - Sisteme de securitate:
 - Criptarea datelor cu SSL/TLS pentru transferurile online,
 - Autentificare în doi pași (2FA) pentru accesul în cont,
 - Protecție anti-DDoS (de exemplu, prin Cloudflare).
- 🚦 Posibile amenințări și riscuri
 - Atacuri DDoS (Distributed Denial of Service)
Exemplu: în perioada Black Friday, site-ul poate fi supraîncărcat de trafic malițios, afectând accesul clienților reali.

➤ Injectii SQL și XSS (Cross-site scripting)

Exemplu: un atacator ar putea introduce cod malițios într-un formular de căutare sau comentariu, ceea ce ar putea compromite conturile altor utilizatori.

➤ Scurgeri de date personale

Exemplu: dacă un angajat descarcă accidental (sau intenționat) o listă de clienți cu tot cu date personale, poate duce la încălcarea GDPR și pierderi de imagine.

➤ Acces intern neautorizat

Exemplu: un angajat din logistică care accesează datele financiare ale clienților, fără a avea atribuții în acel domeniu.

➤ Pierderea datelor

Exemplu: o pană de curent sau un atac ransomware care criptează baza de date poate duce la pierderea comenzilor recente.

2. Alegerea principiilor O-ESA (Open Enterprise Security Architecture)

O-ESA este un cadru folosit pentru dezvoltarea de arhitecturi de securitate în cadrul companiilor mari. Din cele 12 principii generale, am selectat cele mai relevante 4 pentru eMag:

➤ Defense in Depth (Apărare în adâncime)

Ce înseamnă: Fiecare componentă a sistemului trebuie protejată, nu doar perimetrul.

Exemplu concret pentru eMag:

- Pe lângă firewall, eMag ar trebui să aibă și autentificare 2FA pentru angajați, criptare a bazei de date, backup automat, și un sistem de detectare a intruziunilor.

De ce e important: Dacă un strat e compromis (de ex. interfața web), alte straturi pot opri atacatorul (ex: autentificare, criptare, limitare a accesului).

➤ Least Privilege (Principiul minimului necesar de acces)

Ce înseamnă: Fiecare utilizator/angajat trebuie să aibă acces doar la informațiile și funcțiile necesare rolului său.

Exemplu concret pentru eMag:

- Un angajat din call center să poată vedea doar statusul comenzii, nu și detaliile de plată ale clientului.

De ce e important: Previne scurgerile interne de date și atacurile venite din interior (ex: acces neautorizat la datele financiare).

➤ Security by Design (Securitate încă din faza de proiectare)

Ce înseamnă: Securitatea trebuie luată în calcul de la începutul dezvoltării unui sistem, nu adăugată ulterior.

Exemplu concret pentru eMag:

- Înainte de lansarea unei funcții noi, cum ar fi plata prin criptomonede, trebuie efectuate teste de securitate (ex: testare penetrantă, audit de cod).

De ce e important: Corectarea vulnerabilităților după lansare este mai costisitoare și mai riscantă.

➤ Accountability (Responsabilitate și trasabilitate)

Ce înseamnă: Toate acțiunile efectuate în sistem trebuie să fie urmărite și atribuite unei persoane sau unui sistem.

Exemplu concret pentru eMag:

- Loguri pentru toate accesările bazei de date și notificări automate în caz de comportament suspect.

De ce e important: În cazul unui incident de securitate, eMag poate vedea cine, ce, când și de ce a făcut o anumită acțiune.

3. Evaluarea securității sistemului actual (prin prisma O-ESA)

Principiu O-ESA	Aplicabilitate la eMag	Puncte tari	Puncte slabe
Defense in Depth	Parțial aplicat – criptare, firewall, 2FA	Infrastructură de bază solidă	Posibil lipsă de testări automate sau SIEM
Least Privilege	Probabil implementat în parte	Control pe roluri	Posibil acces prea larg pentru unii angajați
Security by Design	Apare în procesele IT moderne	Sisteme moderne, interfață curată	Lansări rapide pot duce la omisiuni de testare
Accountability	Implementat parțial prin loguri și audituri	Audit de bază activ	Lipsă transparență publică asupra incidentelor

4. Plan de îmbunătățire a securității la eMag (bazat pe O-ESA)

Obiectiv securitate	Măsurile concrete	Principiu O-ESA	Termen estimativ
1. Protejarea tuturor nivelurilor	Implementare SIEM (ex: Splunk) pentru detectarea atacurilor în timp real	Defense in Depth	4 luni
2. Limitarea accesului angajaților	Audit de acces + implementarea RBAC (ex. acces granular pe roluri)	Least Privilege	2 luni
3. Îmbunătățirea procesului de dezvoltare	Introducerea testelor automate de securitate în CI/CD (ex: SonarQube, Checkmarx)	Security by Design	3 luni
4. Creșterea trasabilității	Activarea logurilor detaliate + revizuirea regulată a acestora (log review)	Accountability	lunar
5. Plan de reacție la incidente	Crearea unui playbook pentru răspuns la incidente și simulări periodice	Defense in Depth + Accountability	2 luni
6. Instruire internă	Training de securitate cibernetică pentru toți angajații + simulări de phishing	Least Privilege + Design	continuu

Concluzie

Sistemul informațional eMag este bine dezvoltat și include multe componente moderne, însă, având în vedere riscurile crescânde în mediul digital, aplicarea principiilor O-ESA este esențială.

Prin:

- întărirea securității la toate nivelurile,
- limitarea accesului,
- dezvoltarea cu securitatea în minte,
- și trasabilitate clară,

eMag își poate consolida poziția de lider în eCommerce și poate asigura protecția clienților săi împotriva riscurilor tot mai sofisticate.